ACC-04 · Password Standard & Self-Service Password Reset

What a password must be, why one gets rejected, and how a person resets their own without contacting anybody.

Field	Value
Document ID	ACC-04
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	B. Account Usage
Operating tier	Tier 1 — the Service Desk (“the front door”, the service desk address). Configuration is Tier 3; the conversation is Tier 1’s.
Review cycle	Every six months while a move to Entra is under way, then annually.
Closes	Two gaps most Tier 1 password guides have: why a password was rejected, and whether Tier 1 can see self-service reset status.

1. Purpose

This document states the organization’s password requirements and the self-service path for resetting one. It exists because Tier 1 currently cannot answer the most common follow-up question it receives — “why was my password rejected?” — and because self-service reset is the single largest available reduction in the department’s workload.

A good Tier 1 password guide names both of these as gaps and leaves them blank rather than inventing an answer. This document fills them.

> **The scale of the prize**
> On most desks, password resets and lockouts together are one of the biggest ticket categories, and login and access problems often make up half of what end users raise. Measure your own figure before you change anything (§9).
> Every one of those that self-service absorbs is a ticket that never opens. Not a ticket closed faster — a ticket that does not exist.

2. Scope

- Password composition, length, reuse and expiry for every account class in ACC-01 §3.
- Self-service password reset: configuration, rollout and the end-user path.

- Assisted reset, where self-service cannot serve. Out of scope: MFA method registration and recovery, which is ACC-03; lockout triage, which is ACC-05; identity verification before any assisted action, which is ACC-06 and is mandatory before anything in §7.

3. The password standard

Requirement	What to check today	Target state
Minimum length	The default domain policy, every fine-grained policy, and Entra. Eight characters is a common legacy setting.	14 characters for staff, 12 for end users, 16 for privileged accounts
Complexity	Whether character-class rules are on.	No character-class requirement. Length and a banned-password list do more for security and far less damage to usability.
Expiry	The maximum password age in every policy, read carefully (§3.1).	No scheduled expiry. Forced rotation drives predictable increments (Spring2026!, Spring2026!!) and generates lockouts without evidence of benefit. Rotation on evidence of compromise only.
Reuse (history)	The history count, alongside the minimum password age. A history of 3 with a minimum age of 0 lets someone cycle back to their original password in four changes.	Previous 10 passwords blocked, with a minimum password age that makes cycling impractical.
Minimum password age	Often 0 — a password can be changed any number of times in a minute.	One day, so that history cannot be defeated by rapid cycling.
Banned passwords	Whether the Entra custom banned list has anything in it, whether the banned-password check is enabled, and whether on-premises enforcement is in Audit or Enforce.	A custom banned list with your organization's name, abbreviations, mascot, town and seasonal and year patterns, ENFORCED — and extended to the domain controllers in Enforce mode, not Audit. Local terms are what local attackers actually try.
Lockout threshold	The threshold and duration in AD and in Entra, and whether any fine-grained policy sets it to 0.	Aligned across on-premises and cloud so a person cannot be locked in one and not the other, and never disabled for any population.
Cloud password expiry	The Entra expiry setting, and how many synced accounts carry DisablePasswordExpiration. If almost all do, the cloud setting is inert and AD governs.	One expiry regime, stated once, applying to a population somebody can name.
Reversible encryption	Should be disabled.	Unchanged.

How to read it, read-only: Get-ADDefaultDomainPasswordPolicy and Get-ADFineGrainedPasswordPolicy against your PDC emulator for the on-premises half, and the Entra password protection and authentication settings (PowerShell 7 with the Graph SDK, or the admin center) for the cloud half. Record who ran it and

when. If one half cannot be read, say so in the document rather than implying the half you have is the whole picture.

3.1 Fine-grained policies override the default, and they need answering before this document publishes

Active Directory allows fine-grained password policies to override the default for named groups. They are often undocumented. Lower precedence wins, so where a person is subject to two, the lower number governs. For each one, record its precedence, its settings, the group it applies to, and who is actually in that group.

> **COMMON FINDING 1 — a policy that expires passwords every hour, not every 90 days**
>
> A default policy renders a 90-day maximum age as “90.00:00:00” — days, then hours, minutes, seconds. A fine-grained policy that renders as “01:00:00”, with no day component, is ONE HOUR.
>
> If a population is on an hourly expiry, it is very likely a substantial cause of your lockout volume. A password that expires hourly does not present to the person as an expiry; it presents as “I cannot get in”, which is reported and categorised as a lockout.
>
> It also defeats itself. With a short history and a minimum password age of 0, someone forced to change hourly can return to their original password after a few changes. The setting generates the maximum possible friction for no security benefit whatever.
>
> BEFORE ANYONE CHANGES ANYTHING: confirm the value and confirm who is in the group. Two commands, both read-only — Get-ADFineGrainedPasswordPolicy “” | Select MaxPasswordAge, AppliesTo, and Get-ADGroupMember for the group it names. A TimeSpan of 1 hour and a TimeSpan of 1 day render differently and the distinction decides whether this is an emergency or a curiosity.
>
> If confirmed: this is a P1 change under GOV-04 with a same-day back-out, not a scheduled one. It should not wait for this document to be approved.

> **COMMON FINDING 2 — account lockout disabled for a whole population**
>
> A lockout threshold of 0 in Active Directory means no lockout: an attacker may guess a password an unlimited number of times without the account ever locking. Check every fine-grained policy for it.
>
> It also raises a diagnostic question worth pursuing: if a population cannot be locked out in AD, where are its lockout tickets coming from? Entra smart lockout, a third-party identity provider, or password expiry being reported as lockout are the usual candidates. Answering that tells you what is actually generating your lockout volume.
>
> ACTION: Tier 3 to confirm both findings and report to Tier 4 within five coverage days. Owner: a named Tier 3 lead.

3.2 Check whether the on-premises and cloud policies agree — they often do not

Control	What a mismatch looks like	Consequence
Lockout threshold	AD locks after 5 failed attempts; Entra after 10.	A person can exhaust AD and be locked on-premises while the cloud has counted half. Tier 1 sees “locked out” for one service and “working” for another, on the same credential, in the same minute.
Lockout duration	AD locks for 25 minutes; Entra for 60 seconds, increasing.	The advice “wait a minute and try again” is right for one and wrong for the other, and nobody has been told which is which.
Password expiry	AD at 90 days, a fine-grained policy at something else, Entra at 180 days but overridden for most synced accounts.	Several different numbers exist. AD governs in practice when almost every account is synced and carries DisablePasswordExpiration.
Banned password list	On-premises agents off or in Audit; Entra custom list empty and the check disabled.	Only Microsoft’s global list is doing any work. The local terms an attacker would actually try are all permitted.

> **COMMON FINDING 3 — password protection configured but switched off**
>
> A Password Rule Settings object in the tenant means somebody once went to configure this. Check EnableBannedPasswordCheck, the custom banned list, EnableBannedPasswordCheckOnPremises and BannedPasswordCheckOnPremisesMode.
>
> If the feature is there and doing nothing beyond Microsoft’s global list, enabling the custom list and populating it with the terms in the target-state column is perhaps an hour of work and needs no project.
>
> The on-premises half is a larger piece: it requires Entra ID P1 and agents on the domain controllers, and if most accounts are synced, password protection does not reach the population that matters until that is done. Confirm the licence position first (M365-20), because that decides whether this is an afternoon or a project.

The target-state column follows current NIST and Microsoft guidance: length over complexity, banned lists over character classes, and no scheduled expiry. It is a deliberate reduction in friction on the population generating the most lockouts, and it needs Head of IT approval because it will read as a relaxation to anyone who learned password policy years ago.

---

4. Why a password gets rejected — the Tier 1 answer

This is the table Tier 1 asked for. It answers the question without needing to know the policy by heart.

What the person says	Almost certainly because	What Tier 1 says
“It says my password doesn’t meet requirements”	Too short, or on the banned list.	Ask them to try a longer passphrase — three or four unrelated words. Do not ask what they tried.

What the person says	Almost certainly because	What Tier 1 says
“It says I can’t reuse it”	It is one of their recent passwords.	Explain that recent passwords are blocked and suggest something genuinely new, not an increment.
“It won’t accept it but it worked before”	They are hitting a banned-list term, or a policy differs between the portal and the device.	Take the detail and escalate to Tier 2 if it repeats — a policy mismatch is a real finding, not a user error.
“It changed but my laptop still wants the old one”	Not a password problem. The device has not synchronised.	Have them connect to the network or VPN and lock/unlock. This is a very common false lockout (ACC-05).
“It keeps asking me to change it”	A temporary password requiring change, or an expiry policy still in force.	Check which. If a temporary password was issued, walk them through setting a permanent one.
“I don’t want to change it, I just forgot it”	Nothing is wrong.	Self-service reset — §5. Stay with them while they do it.

One rule for this conversation: never ask a person to tell you the password they tried, and never ask for their current one. Tier 1 does not need it, and asking normalises exactly the behaviour ACC-15 prohibits.

---

5. Self-service password reset

5.1 What it does

A person with two registered authentication methods can reset their own password at aka.ms/sspr, verified through those methods, with no ticket and no contact. Where the device is Entra-joined, they can do it from the Windows sign-in screen without a second device — which matters, because the commonest version of this problem is a person locked out of the only computer they have.

5.2 Rollout — in this order

1. Confirm the tenant configuration: two methods required, security questions NOT enabled as a method, and the reset actually completing end to end on a real test account.
2. Enable for a pilot group of IT staff first. Reset a real password. Do not proceed on the strength of the configuration screen looking correct.
3. Enable the Windows sign-in screen option for Entra-joined devices, and test it on a device that is genuinely locked out rather than one that is merely signed out.
4. Extend to staff. Measure assisted-reset volume weekly against the April–August baseline.
5. Extend to everyone else, the largest population and the largest prize. Expect a temporary rise in tickets as people discover the feature; this is not failure.
6. Put the reset link in the mail signature of every service desk reply about access, on the knowledge base portal, and on the Tier 1 desk card. A capability nobody knows about does not reduce anything.

5.3 Who cannot use it, and what happens instead

Situation	Path
Fewer than two methods registered	Self-service cannot verify them. Verify identity per ACC-06, then Tier 2 issues a Temporary Access Pass (ACC-03 §5.4).
Account is locked rather than forgotten	Reset does not clear a lockout. See ACC-05 — resetting a password that was not the problem is the commonest wasted action in the queue.
Account is disabled, unlicensed, or blocked by policy	Not a password matter at all. ACC-05 §2 distinguishes these.
Privileged account	Never by self-service. Tier 3, after Tier 1 or Tier 2 in-person verification (ACC-07).

6. What Tier 1 can see, and what it cannot

The second gap most Tier 1 guides have. Tier 1 cannot help a person register methods it cannot see, and cannot tell whether self-service will work for them without knowing their registration state.

Tier 1 should be able to see	Tier 1 must never be able to do
Whether the person has registered authentication methods, and how many	Reset a password directly
Whether the account is enabled, disabled or locked	Add, remove or reset an MFA method
Whether a licence is assigned	Change group membership or permissions
Recent sign-in success or failure and its result reason	Read a BitLocker recovery key (DEV-01 §5)
Whether a Conditional Access policy blocked the sign-in	Anything requiring an admin centre

> **The access this requires, and why it is worth granting**
>
> The left-hand column is satisfied by a read-only directory role rather than by any reset capability. Granting it turns a large number of escalations into Tier 1 resolutions, because most of them are escalated only to find out what the state is.
>
> This is a Tier 3 configuration decision and a Tier 4 approval. It should be taken deliberately: read-only visibility is low risk and high leverage, and withholding it is currently costing Tier 2 time on questions Tier 1 could answer.
>
> Record the decision either way, so the Tier 1 guide can stop listing it as unknown.

7. Assisted reset

Identity verification per ACC-06 is mandatory and comes first. There are no exceptions, including for people the technician knows personally — a habit of skipping it for known people is exactly what makes it skippable for an impostor.

1. Verify identity per ACC-06 and record the tier used.
2. Confirm the password is actually the problem (ACC-05 §2).
3. Prefer a Temporary Access Pass over a temporary password. A temporary password does not expire on use and will still work weeks later.
4. Where a temporary password is unavoidable, require change at next sign-in and deliver it in person, on a verified video call, or to the manager. Never to a personal address and never in the ticket body.
5. Confirm the person has signed in successfully before closing. The outcome is access, not a reset.
6. While you have them: if they have fewer than two methods registered, get the second one registered now. That is what stops the next call.

8. Service levels

Per GOV-06. Stated in that document's terms rather than as a separate matrix.

Request	Commitment
Self-service reset	Immediate. No ticket, no target.
"Why was my password rejected?"	Answered at Tier 1 in the conversation. Not a ticket unless it recurs.
Assisted reset, identity verified	P2 — acknowledged within 4 coverage hours; usually resolved in the same contact.
Fewer than two methods, needs a TAP	P2 at Tier 2.
Suspected policy mismatch between cloud and on-premises	P3 at Tier 3. A real finding, not a user error.

9. Measurement

- Assisted resets per week, against a baseline you measure before changing anything. This is the number that tells you whether self-service is working.
- Share of accounts with two or more methods registered, by population. Self-service cannot serve anyone below two.
- Self-service resets completed per week.
- Tier 1 resolution rate on access contacts, before and after the §6 read-only visibility decision. Report monthly with the GOV-06 pack. Measure the baseline first — without it, any later claim of improvement is unfalsifiable.

10. Records

Record	Held in	Retention
The confirmed §3 values, with the date and who confirmed them	This document	Life of the standard
ACC-06 verification tier for every assisted reset	Ticket — required field	3 years
TAP issues: who authorised, why, tier used	Ticket + Entra audit log	3 years

Record	Held in	Retention
The §6 read-only visibility decision	IT governance record	Life of the decision
Weekly assisted-reset counts	GOV-06 monthly pack	3 years

11. Related documents

ID	Title	Relationship
Tier 1 Guide	Your password reset and account access guide	This document answers two gaps such guides usually have. Revise the guide to cite this one.
ACC-03	MFA Enrollment, Reset & Account Recovery	Method registration, TAP issue, and the phishing-resistant migration.
ACC-05	Account Lockout Triage	Distinguishes a lockout from a forgotten password — §5.3 and §7 both depend on it.
ACC-06	Identity Verification Before Any Account Action	Mandatory gate before anything in §7.
ACC-07	Privileged & Administrative Account Standard	Stricter length, and no self-service.
ACC-15	Acceptable Use & Credential-Sharing Standard	The rule behind “never ask for a password” in §4.
GOV-06	Service Commitments, Priority & Escalation	Supplies §8.
GOV-05	Knowledge Base Article Standard	Format for publishing Appendix B.

Appendix A — Desk card: “why was my password rejected?”

Keep at the desk. Never ask what they tried, and never ask for a current password.

	They say	You say
1	Doesn’t meet requirements	“Try a longer passphrase — three or four unrelated words works best.”
2	Can’t reuse it	“Recent passwords are blocked. Try something genuinely different rather than adding a number.”
3	Worked before, won’t work now	Take the detail. If it happens twice, escalate — that may be a real policy mismatch.
4	Changed it, laptop wants the old one	“Connect to the network or VPN, then lock and unlock.” Not a password problem.
5	Keeps asking me to change it	Check for a temporary password; help them set a permanent one.
6	Just forgot it	aka.ms/sspr — stay on the call while they do it.

	They say	You say
7	Forgot it, and has no MFA registered	Self-service cannot verify them. Verify per ACC-06, escalate to Tier 2 for a Temporary Access Pass.
8	Locked out rather than forgotten	Go to ACC-05. Do not reset — it will not clear a lockout.

Appendix B — End-user text for publication

Source text for the knowledge base. Format per GOV-05 before publishing.

Resetting your password	Go to aka.ms/sspr. You will be verified through one of the security methods you registered, then asked for a new password. No need to contact anyone.
Choosing a password	Length matters more than symbols. Three or four unrelated words make a strong password that you can actually remember. Avoid anything containing the organization's name, its mascot, a season or a year.
If reset does not work	You probably have fewer than two security methods registered, which means we cannot verify you automatically. Contact the service desk — you will be asked to confirm your identity in person or on a short video call with photo ID.
Register a second method now	The five minutes it takes today is what lets you fix your own account at 11pm the night before a deadline. Go to aka.ms/mysecurityinfo.
We will never ask for your password	Not by email, not on the phone, not in a ticket. Anyone who does is not IT — report it.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.